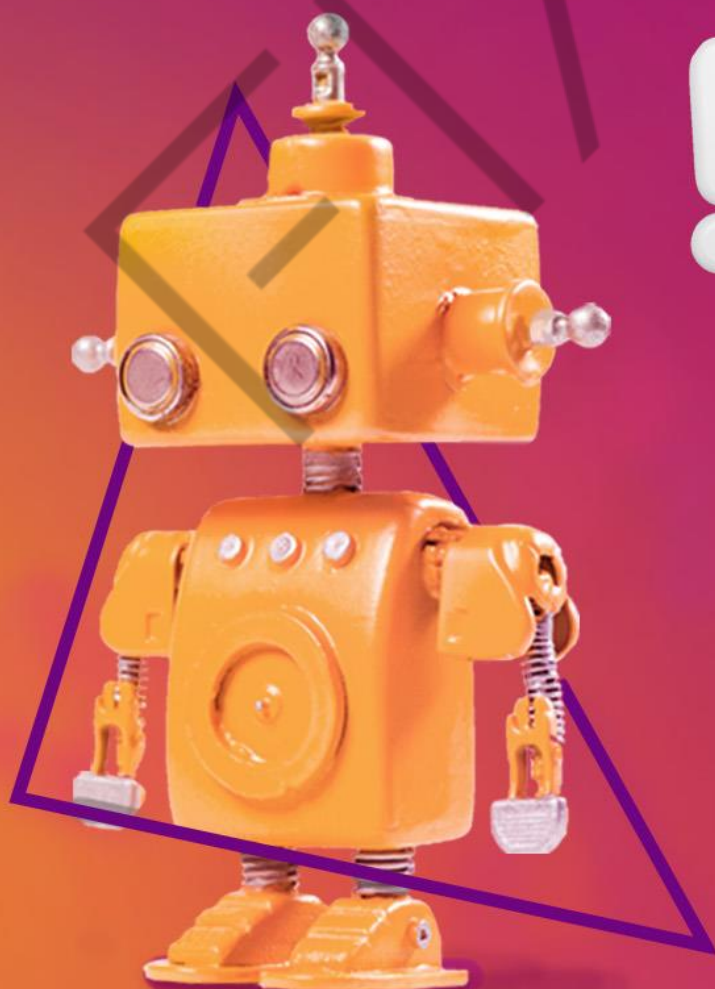


OFFSEC

# ANÁLISE DE VULNERABILIDADE



5

LISTA DE FIGURAS

Figura 1 – Firewalking .....12

Figura 2 - Score.....15

Figura 3 – CVSS .....16



## SUMÁRIO

|                                                                                  |    |
|----------------------------------------------------------------------------------|----|
| ANÁLISE DE VULNERABILIDADE .....                                                 | 4  |
| 1 O QUE SÃO VULNERABILIDADES? .....                                              | 4  |
| 2 VARREDURAS .....                                                               | 5  |
| 2.1 Verificações de vulnerabilidade no serviço do servidor: .....                | 7  |
| 2.2 Verificações de vulnerabilidade no servidor da web e no banco de dados ..... | 8  |
| 2.3 Verificações de vulnerabilidade de firewall .....                            | 10 |
| 3 ANÁLISE DE VULNERABILIDADES .....                                              | 12 |
| REFERÊNCIAS .....                                                                | 19 |

## ANÁLISE DE VULNERABILIDADE

### 1 O QUE SÃO VULNERABILIDADES?

Vulnerabilidades são pontos fracos que podem ou não ser exploráveis. As vulnerabilidades conhecidas são categorizadas e referidas pelo número de vulnerabilidades e exposições comuns (CVE). Depois de descobrir *hosts* e portas abertas, você pode realizar uma varredura de vulnerabilidade para verificar se os serviços que estão escutando nessas portas têm vulnerabilidades conhecidas.

Uma varredura de vulnerabilidade envolve o envio de pacotes ou comandos especialmente criados ao serviço para ver como ele responde. Se o serviço estiver vulnerável a um ataque específico, isso ficará aparente na resposta. Os serviços corrigidos contra a vulnerabilidade responderão de maneira diferente.

Os scanners podem ser mais generalizados ou focar em destinos específicos, como servidores Linux, servidores SQL, aplicativos da web ou dispositivos de rede. Dependendo da ferramenta, os scanners de vulnerabilidade podem ou não tentar realmente explorar a vulnerabilidade e coletar evidências (geralmente um arquivo roubado) de uma exploração bem-sucedida. Algumas ferramentas permitem selecionar o tipo de destino. Alguns scanners de vulnerabilidade podem usar a saída de uma verificação de porta para concentrar seus esforços.

Aqui está um exemplo do Nmap descobrindo servidores da web na rede e depois canalizando sua saída para o Nikto para verificação de vulnerabilidades:

```
nmap -p80,443 10.0.1.0/24 -oG - | nikto.pl -h -frequência
```

Os scanners de vulnerabilidades usados incluem:

- OpenVAS.
- Nexpose/Nexpose Community Edition.
- Comunidade Retina.
- MBSA (Microsoft Baseline Security Analyzer).
- Nessus/Tenable.

- Scripts Nmap NSE A.

## 2 VARREDURAS

**Compliance scanning** envolve varreduras que verificam se sua rede segue certos requisitos de política. Essas políticas podem ser impostas por lei, setor ou empresa individual. As empresas que realizam testes de conformidade internos podem usar ferramentas genéricas de verificação para testar seus controles.

A verificação de conformidade regulatória e do setor, no entanto, pode ser muito mais complexa, com multas acentuadas ou até prisão por não conformidade criminosa. Por esse motivo, muitas organizações compram software especializado ou até contratam ajuda profissional ao realizar verificações de conformidade regulatória. Algumas organizações, como o PCI Security Standards Council, publicam uma lista de fornecedores de verificação aprovados (ASVs).

As **varreduras de vulnerabilidade** do host envolvem a execução de testes em um sistema operacional, incluindo seus serviços padrão. Muitas vezes, o foco é um único host. Os hosts não podem apenas executar serviços de rede comuns, mas também costumam ter aplicativos especializados que usam portas não padronizadas e escolhidas dinamicamente.

Hosts comprometidos também podem ter backdoors de malware escutando em portas incomuns. O desafio será mapear a porta descoberta para o processo de escuta real. Você não pode supor que uma porta conhecida esteja realmente sendo usada pelo serviço esperado.

Aqui estão alguns exemplos de uso do Nmap para a verificação de vulnerabilidades do *host*:

`nmap -Pn --script vuln <target>` (Verifique vulnerabilidades comuns).

`nmap -Pn --script exploit <target>` (Examine as vulnerabilidades e tente explorá-las automaticamente).

`nmap --script dos -Pn <target>` (Teste para verificar se um host está vulnerável a ataques de negação de serviço).

`Nmap -sV -vv <target>` (Verifica e interroga as portas para obter informações sobre a versão do serviço. Produz uma saída muito detalhada).

Um bom scanner de vulnerabilidade deve ser capaz de identificar serviços comuns em execução no hospedeiro. Se você estiver varrendo para fins defensivos e não puder identificar o processo subjacente, poderá executar o comando `netstat` no host para obter mais informações.

Linux: `netstat -natp`

Windows: `netstat -nabo`

Os serviços de rede são serviços comuns que você pode encontrar em praticamente qualquer rede. Isso geralmente inclui:

- DHCP.
- DNS.
- WINS (herdado, menos comum hoje em dia).
- Serviços de autenticação / diretório.
- E-mail.
- Arquivo e impressão.
- Web.
- FTP.
- Fax.
- Acesso remoto.

Quase todos os serviços de rede foram vulneráveis a ataques em algum momento. Geralmente, a vulnerabilidade está no produto ou na implementação específica. Em alguns casos, no entanto, a vulnerabilidade está menos no servidor e mais no próprio processo. Por exemplo, o DHCP é baseado em difusão sem autenticação. Isso significa que um servidor DHCP não autorizado que entregue endereços IP incompatíveis seria muito prejudicial para a rede.

Ao verificar os serviços de rede, você pode usar um bom scanner geral de vulnerabilidades. Se sua rede possui serviços incomuns, talvez você precise usar uma ferramenta especializada.

## **2.1 Verificações de vulnerabilidade no serviço do servidor:**

O termo servidor pode se referir a um computador dedicado a atender clientes na rede ou a um aplicativo especializado instalado nesse computador. Os servidores (geralmente) executam sistemas operacionais configurados para lidar com centenas ou mesmo milhares de clientes simultâneos.

Alguns exemplos de sistemas operacionais de servidor incluem Windows Server 2016, FreeBSD, Solaris, Ubuntu Server e Red Hat Enterprise. Os SOs de servidor geralmente são fornecidos com os serviços de rede padrão instalados. Eles também facilitam a instalação de serviços de rede adicionais, incluindo aplicativos que consomem muitos recursos, como servidores de e-mail e banco de dados.

Do ponto de vista da verificação de vulnerabilidades, não há diferença prática entre um serviço de rede e um serviço de servidor, já que os serviços de rede são executados em servidores e os servidores fornecem seus serviços em uma rede. Ao testar os serviços do servidor, você pode começar com um scanner de vulnerabilidades padrão. Se você possui serviços especializados, pode precisar de uma ferramenta configurada para esse serviço.

## 2.2 Verificações de vulnerabilidade no servidor da web e no banco de dados

Os servidores e bancos de dados da web oferecem uma oportunidade única para a verificação de vulnerabilidades. Embora eles frequentemente trabalhem juntos, na verdade são serviços separados, cada um com suas próprias vulnerabilidades e portas de escuta. Eles geralmente são instalados em computadores separados e têm seus próprios endereços IP.

Os servidores da web geralmente são voltados para o público, enquanto os servidores de banco de dados estão quase sempre na rede privada. O servidor da web terá uma conexão de *back-end* com o servidor de banco de dados.

A maioria dos servidores de banco de dados usa a linguagem SQL e escuta na porta TCP ou UDP 1433. Se você tiver acesso à rede interna, tente digitalizar o servidor SQL diretamente. Ou, se o seu acesso for pelo servidor da web, tente digitalizar o aplicativo da web para ver se ele passará comandos ilegais para o servidor SQL (injeção de SQL).

Em aplicativos menores, o servidor da web e o banco de dados podem fazer parte do mesmo aplicativo, instalado no mesmo computador. Aqui estão as possibilidades de verificar um servidor da web e seu banco de dados:

- Examine o servidor da web no TCP 80 ou 443 em busca de vulnerabilidades específicas do servidor da web.
- Procure servidores da web que executam em portas não padrão.
- Examine todos os aplicativos web em execução no servidor web em busca de vulnerabilidades não relacionadas ao SQL.
- Examine o aplicativo web em busca de vulnerabilidades relacionadas à injeção de SQL.
- Examine o servidor SQL diretamente em sua porta (geralmente TCP 1433).

Alguns scanners de vulnerabilidades de aplicativos da web comuns incluem:

- Arachni.
- Metasploit WMAP.
- OWASP ZAP.



- Nikto.
- Grabber.
- Vega.
- Wapiti.

Nas verificações de **vulnerabilidade de aplicativos**, juntamente com serviços conhecidos, outros tipos de aplicativos escutam na rede. Alguns fornecem funcionalidade adicional ao serviço padrão.

Um exemplo muito comum é o aplicativo da web. Aplicativos da web são *scripts* e executáveis incluídos no HTML do site. Eles fornecem conteúdo dinâmico ao usuário e (geralmente) são executados nas portas TCP 80 e 443 padrão do site.

Do ponto de vista da verificação de vulnerabilidades, eles também apresentam um desafio interessante, porque muitos são personalizados. Existem categorias inteiras de vulnerabilidades de aplicativos da web, mas aplicativos individuais terão um comportamento diferente um do outro. Um pentest pode optar por testar o comportamento interessante do aplicativo web, além de usar uma verificação de vulnerabilidade pré-enlatada.

Além dos aplicativos da web, muitos outros aplicativos também escutam na rede. Eles podem ser os mais difíceis de identificar, visto que podem não ser previsíveis nas portas que eles usam. Se o seu scanner não conseguir identificar o serviço de escuta, vá para o *host* e use o comando `netstat` para obter mais informações. Você também pode realizar uma pesquisa no Google por informações postadas pelo fornecedor.

Dispositivos de rede, como roteadores, comutadores e pontos de acesso sem fio, também têm vulnerabilidades. Como servidores, eles têm seus próprios sistemas operacionais com serviços e recursos. Geralmente, eles também são gerenciados remotamente usando HTTP / S, SSH ou telnet.

Devido ao papel central que desempenham na conexão de outros dispositivos, um dispositivo de rede comprometido pode causar sérias interrupções, até mesmo na rede. Como testador de penetração, você deve procurar não apenas serviços vulneráveis e pilhas de protocolos, mas também maneiras de obter acesso administrativo remoto.

Ao digitalizar dispositivos de rede, um scanner geral mostrará portas abertas, porém, talvez não saiba como testar dispositivos específicos. Certifique-se de escolher um scanner que possa segmentar especificamente os dispositivos de rede que você está digitalizando.

Ao digitalizar dispositivos de rede, considere em qual endereço IP o dispositivo pode ser acessado. Por exemplo, é provável que um roteador tenha pelo menos dois endereços IP, mas um switch pode não ter nenhum. Você pode configurar switches de última geração com um endereço IP de gerenciamento ao qual você pode estabelecer uma conexão remota. Considere a varredura de todos os endereços IP disponíveis para o dispositivo de rede, caso a política ou a filtragem de pacotes não permita algum tráfego em algumas interfaces.

### **2.3 Verificações de vulnerabilidade de firewall**

Embora um produto de firewall possa ter vulnerabilidades, a maioria das verificações de firewall é realizada para identificar quais tipos de tráfego o firewall permite e também para testar a eficácia de suas regras. O objetivo principal de um firewall é impedir que pacotes não autorizados cheguem a serviços de escuta. Os firewalls dedicados (dispositivo) controlam o tráfego que flui entre a rede "confiável" e a "não confiável".

Os firewalls pessoais baseados em software protegem o host contra conexões indesejadas. Os firewalls usam conjuntos de regras para determinar se o tráfego é permitido ou não. A maioria das regras são baseadas em:

- Destino ou fonte porta.
- Destino ou endereço IP de origem.
- Tipo de protocolo.
- Payload.

Especialmente trabalhando pacotes, que podem deslizar por meio porque correspondem a uma regra de autorização. Ou o pacote pode não estar bloqueado porque não corresponde suficientemente a uma regra de negação. Além disso, nem todos os firewalls são capazes de inspeção de carga útil.

Você pode enviar códigos maliciosos um firewall por intermédio de uma porta permitida. Por exemplo, se o TCP 80 for permitido, você poderá ocultar uma carga útil no HTTP ou simplesmente definir a porta de destino de qualquer pacote TCP malicioso como 80. Se o firewall estiver apenas olhando para as portas e não para a carga útil, ele permitirá o pacote.

Às vezes, você pode apenas validar a existência de um dispositivo em um endereço IP. Firewalls por design filtram (bloqueiam) o tráfego, a menos que a porta esteja aberta. Isso também significa que, se o host não tiver portas abertas, ele não responderá ao ICMP. Também não enviará nenhum tipo de resposta (incluindo um TCP RST) para um TCP SYN. No entanto, um firewall pode ter uma configuração incorreta ou falha de design que permite a passagem de um pacote especialmente criado, provocando uma resposta do host.

O tipo de pacote que você precisa usar dependerá do produto de firewall, embora você possa começar com algumas vulnerabilidades conhecidas. Por exemplo, a verificação XMAS, na qual os sinalizadores FIN, URG e PSH são gerados no mesmo segmento TCP, funciona contra firewalls que seguem uma interpretação estrita da RFC 793 (a especificação TCP original). Embora isso tenha sido atualizado na maioria das implementações, essa vulnerabilidade ainda existe na natureza.

Há duas abordagens básicas para verificar se há vulnerabilidades em um firewall:

- Se o firewall estiver instalado no host, se for um dispositivo separado no modo transparente ou se fornecer tradução NAT entre as redes pública e privada: verifique a porta pública do endereço do host ou firewall para ver quais portas estão abertas ou estão sendo publicadas. Se você estiver procurando por vulnerabilidades, use pacotes especialmente criados.
- Se o firewall estiver entre duas redes roteáveis (não fornece conversão NAT entre duas sub-redes separadas) e você souber ou adivinhar o endereço IP do host oculto: use o firewalking na interface pública do firewall. Essa técnica usa uma combinação especializada de rastreamento de porta e traceroute para descobrir os detalhes da rede interna. Ele pode mapear roteadores e firewalls adicionais, endereços IP e portas permitidas.

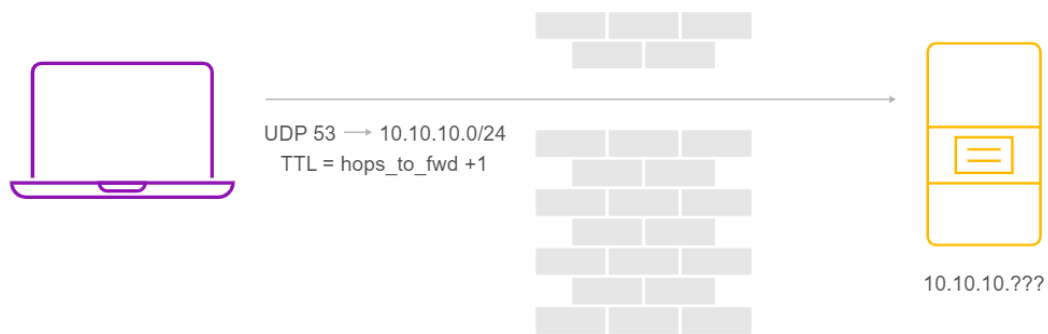


Figura 1 – Firewalking  
Fonte: Elaborado pelo autor (2019)

### 3 ANÁLISE DE VULNERABILIDADES

Para analisar os resultados da verificação de vulnerabilidade não basta apenas enumerar as vulnerabilidades do alvo. Você precisa se aprofundar no que elas podem lhe dizer sobre a organização de destino. Neste tópico, você analisará os resultados da verificação de vulnerabilidade para garantir que esteja usando da melhor maneira possível.

Categorização de ativos, também conhecida como classificação de ativos, é o processo de colocar ativos de negócios com características semelhantes no mesmo grupo. Isso ajuda a empresa a definir como funciona com cada ativo e como priorizar quais ativos recebem as proteções de segurança mais fortes.

Da perspectiva de um pentest, categorizar ativos é uma etapa útil para determinar como abordar os esforços de exploração. Você pode tratar ativos que pertencem a uma categoria como menos relevantes para o teste, mesmo que suas vulnerabilidades sejam mais fáceis de explorar. Por outro lado, os ativos pertencentes a uma categoria diferente podem ser de maior importância e valer o esforço de segmentação. Alguns podem até ser mais suscetíveis a um conjunto de ferramentas mais amplo.

As categorias que as empresas ou pentesters usam variam de circunstância para circunstância. Algumas categorias comuns no campo da segurança cibernética incluem:

- Bens públicos, que não apresentam riscos para uma organização se divulgados, no entanto, apresentam risco se modificados ou não disponíveis.
- Ativos privados, que apresentam algum risco para uma organização, se possuídos por concorrentes, modificados ou não disponíveis.
- Ativos restritos, que podem ser limitados a um subconjunto muito pequeno da organização, principalmente no nível executivo (por exemplo, dados contábeis corporativos), onde o acesso não autorizado pode causar sérios distúrbios nos negócios.
- Ativos confidenciais, que teriam um impacto significativo nos negócios e em seus clientes, se divulgados. As informações da conta do cliente, como nomes de usuário e senhas, informações de identificação pessoal (PII), informações de saúde protegidas (PHI) e informações de cartão de pagamento (PCI)/dados do titular do cartão (CHD), estariam nessa categoria.

É importante observar que todas essas categorias fluem de um esquema de classificação específico. Basicamente, todas elas estão descrevendo a sensibilidade de um ativo em termos das proteções de segurança cibernética de que ele precisa. Isso certamente é valioso para um pentester, porque essas categorias ajudam você a tomar decisões sobre quais ativos são potencialmente os mais desafiadores a comprometer, os mais prováveis de serem alvos de invasores, os mais valiosos para um invasor e os mais devastadores para os negócios.

Existem, contudo, outras abordagens para categorização. Por exemplo, você pode categorizar ativos em termos da função que eles desempenham nos negócios. Essas categorias podem incluir:

- Pessoas, principalmente pessoal, clientes e outras partes interessadas do negócio.
- Hardware, principalmente equipamentos de computação e periféricos.
- Software, principalmente sistemas operacionais e aplicativos.
- Dados, particularmente dados proprietários ou dados sobre pessoas.
- Ambiente físico, principalmente o escritório onde está localizado.

- Processos, particularmente processos que permitem que a empresa forneça produtos e serviços diretamente aos clientes.
- Terceiros, principalmente parceiros de negócios e membros da cadeia de suprimentos da organização.

Como pentester, você pode usar esse esquema de classificação específico, pois decompõe os componentes fundamentais de um negócio. Ser capaz de explorar uma ou mais funções pode ter um impacto maior ou mais abrangente nos negócios de destino.

As varreduras de vulnerabilidade têm o potencial de produzir grandes quantidades de falsos positivos. Existem inúmeras razões pelas quais o scanner pode desencadear um falso positivo, incluindo:

- 1 O fornecedor do scanner pode estar tentando melhorar a aparência do produto, programando o scanner para relatar mais vulnerabilidades do que realmente existem.
- 2 O scanner não consegue reconhecer que outro controle está compensando alguma deficiência identificada.
- 3 O scanner está usando um banco de dados de vulnerabilidades com definições desatualizadas.
- 4 O scanner classifica incorretamente uma vulnerabilidade como mais grave ou fácil de explorar do que realmente é.
- 5 As personalizações no ambiente de destino estão acionando inadvertidamente o scanner para identificar uma vulnerabilidade.
- 6 O scanner não está configurado corretamente; por exemplo, foi fornecido com um destino ou credenciais incorretas.

Como pentester, você deve ser capaz de identificar quando os resultados indicam uma pista falsa em uma vulnerabilidade. Fazer isso ajudará a evitar perder tempo perseguindo uma pista que leva a um beco sem saída.

Existem várias táticas que você pode empregar para identificar falsos positivos; uma das mais eficazes é a validação de resultados. Por meio de um processo de validação, você compara o que aprendeu sobre o ambiente de destino com os resultados individuais da verificação e identifica se os resultados são realmente aplicáveis e precisos.

Por exemplo, seu scanner pode indicar que um Windows Server de destino é suscetível a falhas no SMBv1 (Bloco de Mensagens do Servidor). Todavia, uma verificação de serviço anterior indica que o serviço SMB em execução no servidor está atualizado e executando a versão 3, a mais recente. Portanto, você pode concluir que o scanner está com erro.

Se você estivesse no time azul defensivo, teria mais facilidade em identificar falsos positivos, pois sua compreensão do ambiente de destino estaria completa. Como pentester, pode haver lacunas no seu conhecimento, especialmente se você estiver realizando um teste de caixa preta. Nesse caso, você precisará tentar o seu melhor com o que possui e admitir que não será necessariamente capaz de evitar totalmente os falsos positivos. Você pode optar por realizar mais reconhecimento no ambiente de destino se pretender evitar o maior número possível de falsos positivos.

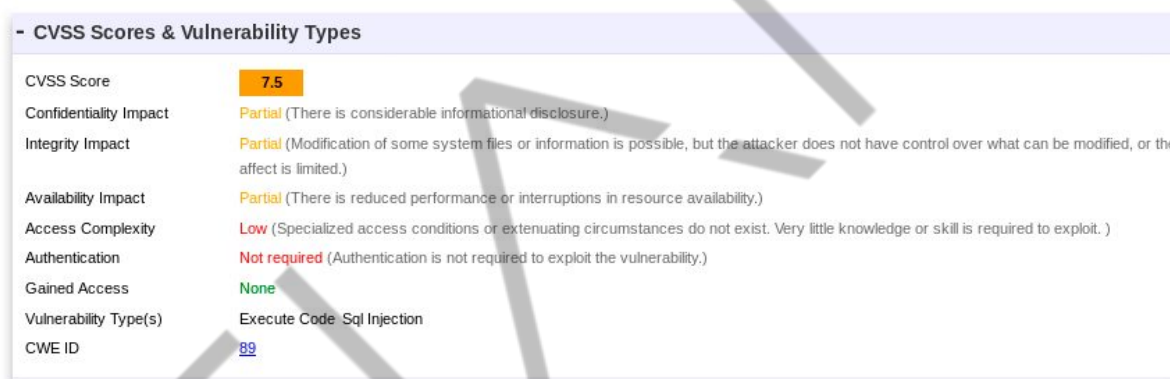
Embora você tenha a liberdade de usar seu próprio sistema para obter níveis de ameaça de pontuação, geralmente é uma boa ideia confiar em um padrão do setor como o CVSS (Common Vulnerability Scoring System) para fazer isso por você.

| Rating   | Score Range |
|----------|-------------|
| None     | 0.0         |
| Low      | 0.1 - 3.9   |
| Medium   | 4.0 - 6.9   |
| High     | 7.0 - 8.9   |
| Critical | 9.0 - 10.0  |

Figura 2 - Score  
Fonte: Elaborado pelo autor (2019)

O CVSS é um padrão aberto que define como os dados de vulnerabilidade podem ser quantificados, levando em consideração os graus de risco para diferentes tipos de sistemas ou informações. Isso é feito usando três grupos de métricas principais (base, temporário e ambiental) para descrever vulnerabilidades de várias maneiras. A pontuação no CVSS (versão 3) é numérica e um intervalo de números também recebe uma classificação.

O CVSS é alavancado por vários bancos de dados de vulnerabilidade reconhecidos pelo setor. O National Vulnerability Database (NVD) do governo dos EUA, que fornece uma lista de vulnerabilidades no banco de dados Common Vulnerabilities and Exposures (CVE), associa cada vulnerabilidade a uma pontuação CVSS.



| - CVSS Scores & Vulnerability Types |                                                                                                                                                                     |
|-------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CVSS Score                          | 7.5                                                                                                                                                                 |
| Confidentiality Impact              | Partial (There is considerable informational disclosure.)                                                                                                           |
| Integrity Impact                    | Partial (Modification of some system files or information is possible, but the attacker does not have control over what can be modified, or the affect is limited.) |
| Availability Impact                 | Partial (There is reduced performance or interruptions in resource availability.)                                                                                   |
| Access Complexity                   | Low (Specialized access conditions or extenuating circumstances do not exist. Very little knowledge or skill is required to exploit. )                              |
| Authentication                      | Not required (Authentication is not required to exploit the vulnerability.)                                                                                         |
| Gained Access                       | None                                                                                                                                                                |
| Vulnerability Type(s)               | Execute Code Sql Injection                                                                                                                                          |
| CWE ID                              | 89                                                                                                                                                                  |

Figura 3 – CVSS  
Fonte: Elaborado pelo autor (2019)

Com a priorização da vulnerabilidade, depois de classificar as vulnerabilidades por nível de ameaça ou consultar um serviço como o CVSS que faz isso por você, você precisará decidir em quais delas dedicar seu tempo e dinheiro. Afinal, seu prazo e orçamento limitados provavelmente o impedirão de testar todas as vulnerabilidades existentes.

Ao priorizar as vulnerabilidades, você determina quais recebem mais atenção quando se trata de fazer pesquisas adicionais sobre como explorá-las. Isso garante que seu tempo e dinheiro estejam sendo usados com eficiência.



Como mencionado anteriormente, os resultados da sua adjudicação terão uma grande influência sobre como você prioriza as vulnerabilidades. Aquelas marcadas como "críticas" serão os alvos mais atraentes e podem acabar sendo os mais fáceis de explorar e/ou levar a resultados mais significativos. No entanto, nem sempre é tão simples quanto dividir por classificação e depois prosseguir a partir daí.

Às vezes, você precisará encontrar um equilíbrio entre a probabilidade de exploração e o impacto dessa exploração. Os ambientes exclusivos da organização cliente quase sempre informam como você faz isso. Por exemplo, pode haver uma vulnerabilidade "crítica" que permite a escalação de privilégios em um controlador de domínio do Windows, o que pode levar a graves consequências para a organização.

Porém, a exploração pode exigir certos fatores que são muito difíceis de replicar no ambiente da organização. Assim sendo, você pode rebaixar essa vulnerabilidade com base no seu conhecimento do destino. Da mesma forma, você pode promover uma vulnerabilidade "alta" ou "média" que ofereça uma melhor oportunidade para exploração, mesmo que seu impacto não seja tão grave.

É importante ter em mente que as classificações de ameaças não são o único fator que contribui para seus esforços de priorização. Você também precisa considerar o custo da mitigação. Mesmo que o impacto de uma vulnerabilidade não seja particularmente alto, pode ser muito difícil ou caro para a organização corrigi-la. Consequentemente, há uma probabilidade maior de que a organização decida aceitar o risco e renunciar à mitigação. Isso pode solicitar que você promova a vulnerabilidade, porque há uma chance de ser mais fácil de explorar.

Ao analisar os resultados da verificação de vulnerabilidade e observar o ambiente de destino, você encontrará condições recorrentes e/ou temas comuns. Podem ser:

- Segurança física relaxada.
- Funcionários que não seguem a política corporativa ou as melhores práticas.
- Falta de treinamento adequado em segurança cibernética.
- Falta de correção e atualização de software.
- Falta de proteção do sistema operacional.

- Más práticas de desenvolvimento de software.
- Uso de protocolos de rede desatualizados.
- Uso de protocolos criptográficos obsoletos.

Ao identificar temas comuns como esses, você pode se deparar com um padrão de comportamento. Esse padrão pode se estender a ativos que você ainda não testou ou não planejou testar. Se você planeja testá-los no futuro, pode fazer certas suposições e suposições educadas que podem facilitar seu trabalho ou levá-lo a certos caminhos que, de outra forma, não teria seguido. Por fim, a identificação de temas comuns fornece uma imagem mais completa do seu ambiente de destino e de seus pontos fracos.

## REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014

WILHELM, T. **Professional Penetration Testing**: Creating and Learning in a Hacking Lab. 2. Waltham, MA: Syngress, 2013.